

ENTERPRISE SECURITY ASSESSMENT LAB

API Security Evidence Documentation Report

crAPI Homepage Availability Evidence

Professional Portfolio Edition - Authorized API Security Lab Evidence

Field	Details
Test Area	crAPI homepage accessible
Result Type	Target availability proof
Evidence Report File	01-crapi-homepage-browser-evidence-report.pdf
Testing Phase	Target Availability Validation
Tool / Component	Browser / crAPI Web UI
OWASP / Security Mapping	Preparation / Scope Validation
Repository Path	02-api-security/reports/evidence/
Prepared For	GitHub recruiter portfolio documentation

This report documents one API Security evidence row as a standalone professional artifact. It includes the embedded screenshot, what it proves, the methodology context, command/workflow, sanitized output style, risk interpretation, remediation guidance, and publication redaction requirements.

1. Embedded Evidence Screenshot

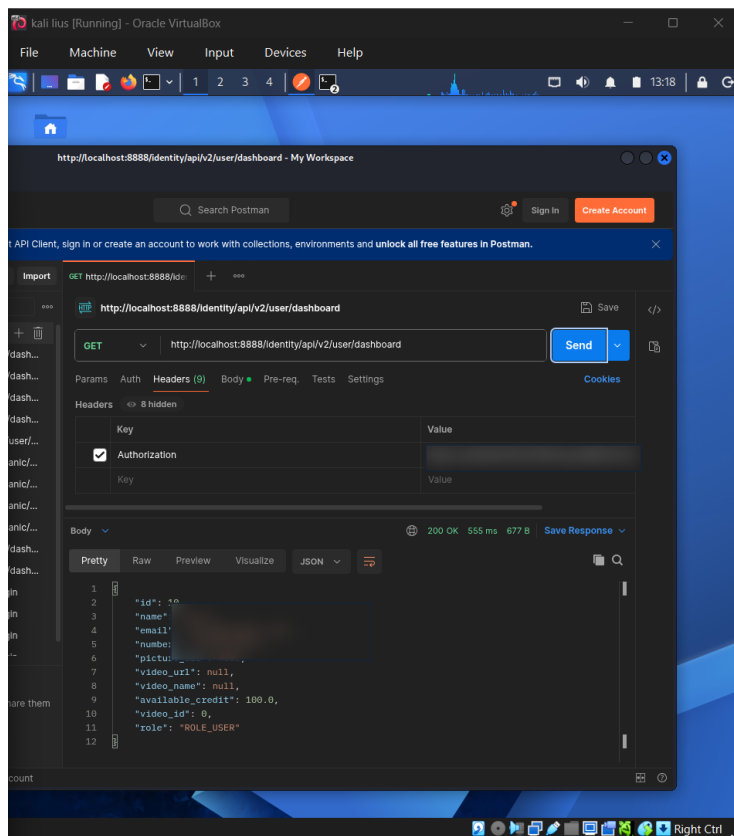


Figure 1 - Embedded screenshot evidence for: crAPI homepage accessible

What this evidence proves

The screenshot shows the crAPI interface reachable in the browser. This confirms target availability and provides a visual checkpoint before authentication, API request collection, and endpoint testing.

Evidence handling note

The screenshot has been prepared for GitHub publication. Sensitive fields such as credentials, tokens, JWTs, cookies, personal data, host values, or other secrets are blurred or represented as redacted values where needed.

2. Assessment Context and Methodology Placement

Area	Value
Testing Phase	Target Availability Validation
Tool / Component	Browser / crAPI Web UI
Assessment Objective	Confirm that the crAPI web application is reachable from the browser and ready for API workflow testing.
Result Type	Target availability proof
OWASP / Security Mapping	Preparation / Scope Validation

Why this evidence matters

Availability validation confirms that the lab target is responding normally. It also establishes that subsequent Postman and Burp traffic belongs to the intended crAPI lab.

Command / workflow used

```
Open browser to http://localhost:8888/  
Verify crAPI homepage loads  
Confirm application UI is reachable before sending API requests
```

Sanitized output style

```
HTTP 200 OK / application page rendered  
Target: local crAPI lab  
No production host involved
```

3. Professional Interpretation

This evidence row should be interpreted as: **Target availability proof.**

This is not a vulnerability. It proves the target application is reachable. In production, exposed API frontends should be protected by normal authentication, rate limits, and monitoring.

Assessor notes

Good evidence for a portfolio because it proves the target was a controlled vulnerable lab.

How a recruiter or reviewer should read this evidence

The value of this evidence is not only the screenshot itself. The value is that it demonstrates a structured API security testing process: controlled lab setup, targeted testing, safe interpretation of results, and clear separation between confirmed vulnerabilities and controls that rejected attack attempts.

Important reporting distinction

This row is setup or workflow evidence. It supports the assessment chain but should not be described as a security finding by itself.

4. Risk, Impact, and Remediation Guidance

Risk perspective

This is not a vulnerability. It proves the target application is reachable. In production, exposed API frontends should be protected by normal authentication, rate limits, and monitoring.

Recommended remediation / hardening actions

- Keep lab access local-only.
- Avoid exposing vulnerable apps to public interfaces.
- Use a dedicated network for lab exercises.
- Document target URL and scope clearly.

Validation guidance after remediation

- Repeat the same test workflow after remediation and compare the response behaviour.
- Confirm that sensitive data is no longer exposed in raw API responses.
- Confirm that unauthorized requests return secure error responses such as 401 or 403 where appropriate.
- Confirm that security controls are enforced server-side, not only in the frontend or client collection.

5. GitHub Publication and Redaction Guidance

Sensitive values to redact before public upload

- Browser profile names if private.
- Internal hostnames if sensitive.
- Any visible account information.

General API evidence redaction checklist

- Blur JWT access tokens, bearer tokens, OAuth codes, cookies, and authorization headers.
- Blur email addresses, phone numbers, user IDs, vehicle IDs, order IDs, and private object identifiers.
- Do not upload Postman environment files containing live variables or secrets.
- Do not upload raw response exports containing personal data or secret-bearing values.
- Use placeholders such as , , and .

GitHub link format for 02-api-security/README.md

`[crAPI homepage accessible](./reports/evidence/01-crapi-homepage-browser-evidence-report.pdf)`

Final classification

This PDF is suitable for a public GitHub portfolio only after the embedded screenshot has been reviewed and sensitive values are confirmed blurred or removed.